SECURITY REVIEW ARTIFACT

Web3 SDL Report

This rerun reviewed the final head of Moonwell PR #578 with the `diff-sdl` workflow and runtime inputs loaded from local `.env` plus public multichain RPCs. The goal was to answer the important question cleanly: not only whether `MIP-X43` executes, but whether the resulting oracle rollout remains semantically correct.

Review date: 2026-03-07

REPOSITORY	**moonwell-contracts-v2**
WORKFLOW	**diff-sdl**
COMMIT RANGE	**85b7a7d70730e8a7aa0255b80acbfd997c211c22..e3579d4832b20162e52f94579b794c30be7dc244**
OUTCOME	**Fail**

Critical 1 **High 1** **Medium 2**

Generated by web3-sdl-workflows browser renderer.

Table of Contents

Engagement Snapshot

Executive Summary

Scope

- Review Objectives
- In Scope
- Out Of Scope
- Evidence Sources

System Overview

- Architecture Summary
- Privileged Roles
- Trust Assumptions
- Critical Assets And Security Properties

Review Context

- Workflow And Stage Coverage
- Change Overview
- New Or Changed Trust Assumptions

Findings Overview

Detailed Findings

- F-101 Base cbETH uses a raw ratio feed instead of the canonical USD path
- F-102 Proposal validation checks wiring but not denomination correctness
- F-103 Smoke oracle integration is too weak for semantic mispricing
- F-104 No invariant suite protects the changed oracle semantics

Verification Summary

- Verification Matrix
- Commands Run
- Coverage Assessment

Blockers

Residual Risks

Recommendations

Immediate Actions

Near-Term Hardening

Monitoring And Follow-Up Review

Appendix

Files And Commits Reviewed

Runtime And Environment Notes

Open Questions

Web3 SDL Report

Engagement Snapshot

FIELD	VALUE
Workflow	`diff-sdl`
Repository	`moonwell-contracts-v2`
Branch / Ref	`PR #578 head` at `e3579d4832b20162e52f94579b794c30be7dc244`
Commit Range	`85b7a7d70730e8a7aa0255b80acbfd997c211c22..e3579d4832b20162e52f94579b794c30be7dc244`
Review Date	`2026-03-07`
Primary Outcome	`Fail`
Final Deliverables	`final-report.md`, `final-report.pdf`, supporting artifacts

Executive Summary

This rerun reviewed the final head of Moonwell PR #578 with the `diff-sdl` workflow and runtime inputs loaded from local `.env` plus public multichain RPCs. The goal was to answer the important question cleanly: not only whether `MIP-X43` executes, but whether the resulting oracle rollout remains semantically correct.

The highest-priority conclusion is that Base `cbETH` is still wired to a raw `cbETH / ETH` ratio feed instead of the repository's canonical USD-composed path. The proposal harness passed, which proves the rollout is executable, but the semantic hard gate failed with a measured drift of about `1977.55x` between the selected feed path and the expected canonical path.

The review also found that proposal validation and smoke integration are both too weak for this defect class. `mipx43.validate` confirms wrapper wiring and constructor state, while the relevant smoke integration only checks that the reported price is greater than zero. Neither protects against a logically wrong but live oracle value.

Stage 3 therefore finished with one confirmed release-blocking defect, one validation blind spot, and one unresolved invariant coverage blocker. The final report bundle is complete because the issue was reproduced with runtime-backed evidence and a deterministic semantic helper.

SEVERITY	COUNT	NOTES
Critical	1	`F-101` is release-blocking and affects market price meaning
High	1	validation blind spot allows the defect through
Medium	2	one smoke-test gap and one invariant-coverage gap
Low	0	none
Informational	0	none

Severity counts summarize the findings confirmed in this run.

Scope

Review Objectives

- Determine whether the final PR head is both executable and semantically safe.
- Verify whether changed oracle config rows preserve the denomination expected by downstream consumers.
- Confirm whether proposal validation and existing tests are strong enough to catch this class of defect.

In Scope

- `proposals/ChainlinkOracleConfigs.sol`
- `proposals/mips/mip-x43/mip-x43.sol`
- `proposals/Configs.sol`
- `src/oracles/ChainlinkOracle.sol`
- `test/integration/LiveProposalsIntegration.t.sol`
- `test/integration/oracle/ChainlinkOEVWrapperIntegration.t.sol`
- `test/unit/ChainlinkOEVWrapperUnit.t.sol`
- live Base address-book entries in `chains/8453.json`

Out Of Scope

- broader protocol economics outside the changed oracle rollout surface
- governance process quality outside the reviewed proposal code
- unrelated invariant suites that do not execute the changed proposal or oracle surface
- off-chain monitoring and operations beyond what the repository already exposes

Evidence Sources

- `git log` and `git diff`
- direct code review
- Foundry build and integration tests
- runtime requirement discovery
- deterministic semantic oracle comparison on Base mainnet

System Overview

Architecture Summary

`MIP-X43` is a multichain governance rollout that deploys and wires OEV wrappers for remaining Moonwell markets on Base and Optimism. The proposal expands oracle config rows, deploys wrappers derived from those rows, points `CHAINLINK_ORACLE` at the resulting wrapper addresses, and validates the deployed state. That makes each oracle config row a security-critical unit because it indirectly controls collateral pricing, borrowing limits, and liquidation behavior.

Privileged Roles

ROLE	AUTHORITY	SECURITY RELEVANCE
`TEMPORAL_GOVERNOR`	owns wrapper configuration and proposal-executed state changes	governance mistakes can propagate invalid pricing across multiple markets
`CHAINLINK_ORACLE`	serves market prices to mTokens	downstream consumer that assumes configured feeds already have the correct denomination
Proposal deployer or harness runner	executes `mipx43` in tests and deployment contexts	determines whether runtime wiring and validation paths are exercised faithfully

Trust Assumptions

- The proposal assumes each configured oracle name represents the denomination expected by `ChainlinkOracle`.
- The review assumes the Base address book in `chains/8453.json` is the canonical source for named oracle and market addresses.
- The native proposal harness is assumed to be the most faithful multichain execution path because it creates and selects the required forks.
- A passing proposal execution is not assumed to prove semantic oracle correctness unless a dedicated expectation check also passes.

Critical Assets And Security Properties

ASSET / PROPERTY	WHY IT MATTERS	FAILURE MODE
Oracle denomination correctness	collateral pricing drives borrowing and liquidation	semantically wrong but non-zero price
Governance rollout integrity	one proposal can change many feeds at once	executable deployment that leaves unsafe market wiring
Validation fidelity	validators should reject semantically wrong configs	address-only validation misses economic defects
Changed-surface coverage	review must exercise the actual diff	unrelated tests create false confidence

Review Context

Workflow And Stage Coverage

STAGE	PURPOSE	RESULT
Stage 1	Threat model	`Completed`
Stage 2	Diff analysis / STRIDE-Web3	`Completed`
Stage 3	Verification	`Completed with one critical finding and one invariant blocker`
Stage 4	Reporting	`Completed`

Change Overview

SURFACE	CHANGE TYPE	RISK RELEVANCE
`ChainlinkOracleConfigs`	config-row expansion and final feed selection	directly changes what unit each market trusts
`mipx43` deploy and validate flow	proposal execution and verification	can validate wiring without validating semantics
`ChainlinkOracle` consumer path	unchanged consumer assumption applied to new config	raw ratio feed can be treated as if it were USD

New Or Changed Trust Assumptions

- The final PR assumes `cbETHETH_ORACLE` is a valid direct substitute for the canonical Base `cbETH_ORACLE` path.
- The final PR assumes wrapper validation plus non-zero price checks imply semantic correctness.
- The final PR assumes runtime success is enough evidence even when the resulting price unit changes.

Findings Overview

ID	TITLE	SEVERITY	STATUS	SURFACE	VERIFICATION
F-101	Base cbETH uses a raw ratio feed instead of the canonical USD path	Critical	Confirmed	ChainlinkOracleConfigs Base cbETH row	semantic drift helper failed
F-102	Proposal validation checks wiring but not denomination correctness	High	Confirmed	mipx43.validate	proposal harness passed despite F-101
F-103	Smoke oracle integration is too weak for semantic mispricing	Medium	Confirmed	testAllChainlinkOraclesAreSet	liveness-only assertion and timeout
F-104	No invariant suite protects the changed oracle semantics	Medium	Confirmed	changed-surface verification	only xWELL invariants exist

Detailed Findings

`F-101` Base `cbETH` uses a raw ratio feed instead of the canonical USD path

Severity: Critical
Status: Confirmed
Category: business logic / oracle semantics
Affected Surface: `proposals/ChainlinkOracleConfigs.sol`, `proposals/Configs.sol`, `src/oracles/ChainlinkOracle.sol`

Why This Matters

This is a direct pricing-integrity failure. If a market expects a USD price but receives a raw `asset / ETH` ratio instead, collateral valuation and liquidation behavior can be materially wrong even though the feed is live and the proposal executes cleanly.

Technical Details

- The Base config row in `ChainlinkOracleConfigs` maps `cbETH` to `cbETHETH_ORACLE`.
- The repository already defines the correct Base path in `Configs.sol` as `cbETH_ORACLE = ETH_ORACLE * cbETHETH_ORACLE`.
- `ChainlinkOracle.getUnderlyingPrice()` and `getPrice()` fetch the configured feed and rescale by decimals. They do not compose a ratio feed into USD.
- The deterministic semantic helper measured `selected_answer_raw=1124650193922520000` and `expected_answer_raw=2224051595339541204057`.
- The resulting ratio between the canonical and selected path was about `1977.55x`, far outside the configured drift threshold.

Evidence

- `proposals/ChainlinkOracleConfigs.sol:41-43`
- `proposals/Configs.sol:278-285`
- `src/oracles/ChainlinkOracle.sol:58-110`
- `check_oracle_semantics.sh` exited `2` with `status=drift_exceeded`

Recommendation

- Replace the Base `cbETH` row with the canonical USD-composed `cbETH_ORACLE` path.
- Add a native regression test that compares changed oracle rows against canonical repository compositions.

Resolution Status

- Open

`F-102` Proposal validation checks wiring but not denomination correctness

Severity: High
Status: Confirmed
Category: validation gap
Affected Surface: `proposals/mips/mip-x43/mip-x43.sol`

Why This Matters

A validator that proves only address wiring and wrapper state can bless a dangerous configuration. That allows governance code to ship a live but semantically wrong oracle path without any failing validation step.

Technical Details

- `_validateFeedsPointToWrappers` only checks that `ChainlinkOracle.getFeed(symbol)` equals the expected wrapper address.
- `_validateCoreWrappersConstructor` checks wrapper state such as `priceFeed`, fee settings, owner, and `cachedRoundId`.
- Neither helper checks denomination lineage, expected quote currency, or price magnitude relative to a canonical path.
- The proposal harness passed even though the semantic helper independently proved the Base `cbETH` path was wrong.

Evidence

- `proposals/mips/mip-x43/mip-x43.sol:343-430`
- `forge test --match-contract LiveProposalsIntegrationTest --match-test testExecutingInDevelopmentProposals -vv` passed
- `F-101` remained confirmed after the same runtime-backed rerun

Recommendation

- Extend proposal validation with denomination-lineage assertions for changed oracle rows.
- Add a coarse sanity assertion for correlated assets such as `cbETH` relative to `ETH`.

Resolution Status

- Open

`F-103` Smoke oracle integration is too weak for semantic mispricing

Severity: Medium
Status: Confirmed
Category: test gap
Affected Surface: `test/integration/oracle/ChainlinkOEVWrapperIntegration.t.sol`

Why This Matters

A smoke test that only proves liveness can create false confidence. A non-zero answer in the wrong unit still passes the assertion, which means the suite cannot defend against the class of issue confirmed in `F-101`.

Technical Details

- The relevant smoke path calls `oracle.getUnderlyingPrice(...)`.
- The only assertion is `price > 0`.
- The broad integration command also timed out under a 120-second bound, which further weakens it as a hard gate for this review.
- Because the changed risk is semantic rather than liveness-only, this suite can at best be advisory.

Evidence

- `test/integration/oracle/ChainlinkOEVWrapperIntegration.t.sol:322-328`
- `timeout 120 forge test --match-contract ChainlinkOEVWrapperIntegrationTest -vv` exited `124`

Recommendation

- Add an expected-versus-observed oracle regression test for the changed row.
- Keep broad smoke coverage as advisory unless it includes denomination-aware assertions.

Resolution Status

- Open

`F-104` No invariant suite protects the changed oracle semantics

Severity: Medium
Status: Confirmed
Category: invariant coverage gap
Affected Surface: changed proposal and oracle verification

Why This Matters

Strict `diff-sdl` review depends on changed-surface coverage, not unrelated repository tests. Without an invariant on the oracle or proposal semantics, this diff still lacks one of the required verification categories.

Technical Details

- The local Foundry invariant directory only contained `xWELLInvariant`.
- The existing invariant handlers model token-owner behavior, not oracle denomination or governance rollout semantics.
- No changed-surface invariant was available to run for Base `cbETH` or the `mipx43` rollout.

Evidence

- `test/invariant/xWELLInvariant.t.sol:17-120`
- `rg -n "invariant|Invariant" test` showed only unrelated local Foundry invariant coverage for this review target

Recommendation

- Add one proposal or oracle invariant that constrains denomination correctness for changed feeds.
- Treat the missing invariant as an open blocker until the changed surface has dedicated coverage.

Resolution Status

- Open

Verification Summary

Verification Matrix

THREAT / FINDING	INTEGRATION	FUZZ	INVARIANT	SEMANTIC / DIFFERENTIAL	RESULT
`F-101`	`LiveProposalsIntegrationTest::testExecutingInDevelopmentProposals`	`testFuzz_GetCollateralTokenPrice_NoRevert`	`none`	`check_oracle_semantics.sh`	`Fail`
`F-102`	proposal harness executes validation helpers	`n/a`	`none`	source inspection of validator logic	`Fail`
`F-103`	`ChainlinkOEVWrapperIntegrationTest`	`n/a`	`none`	smoke assertion review	`Advisory only`
`F-104`	`none`	`none`	`none`	invariant inventory search	`Blocked`

Commands Run

COMMAND	PURPOSE	RESULT	NOTES
`forge build`	compile	`Pass`	fresh checkout compiled cleanly
`forge test --match-contract LiveProposalsIntegrationTest --match-test testExecutingInDevelopmentProposals -vv`	native proposal execution	`Pass`	proves final PR head executes
`forge test --match-path test/unit/ChainlinkOEVWrapperUnit.t.sol --match-test testFuzz_GetCollateralTokenPrice_NoRevert -vv`	narrow fuzz evidence	`Pass`	partial coverage only
`./scripts/check_oracle_semantics.sh ... --asset cbETH --selected-feed cbETHETH_ORACLE --expected-feed cbETH_ORACLE ...`	semantic hard gate	`Fail`	`status=drift_exceeded`
`timeout 120 forge test --match-contract ChainlinkOEVWrapperIntegrationTest -vv`	broad wrapper smoke suite	`Timeout`	advisory only for this review

Coverage Assessment

- Runtime-backed proposal execution was verified directly.

- The critical semantic defect was verified directly with a deterministic helper against live Base addresses.
- Narrow wrapper fuzz coverage exists, but it does not prove denomination correctness.
- The broad wrapper smoke suite remained advisory because it timed out and only asserts liveness on the relevant path.
- No changed-surface invariant exists, so Stage 3 still has one open coverage blocker.

Blockers

- No relevant invariant suite exists for the changed proposal or oracle surface.

Residual Risks

- Similar ratio-versus-USD mistakes can recur anywhere config rows bypass canonical composite-oracle helpers.
- Reviewers can still over-trust passing proposal harnesses unless semantic checks become mandatory.
- Public RPC variability can affect reproducibility for multichain reruns, even though it did not change the conclusion here.

Recommendations

Immediate Actions

1. Replace the Base `cbETH` row with the canonical `cbETH_ORACLE` USD path before rollout.
2. Treat the current configuration as release-blocking.

Near-Term Hardening

1. Extend `mipx43.validate` with denomination-lineage assertions.
2. Add an expected-versus-observed semantic regression test for changed oracle rows.
3. Add one invariant that covers proposal-driven oracle semantics.

Monitoring And Follow-Up Review

1. Monitor changed oracle rows for large magnitude deviations relative to anchor assets such as `ETH`.
2. Rerun the full `diff-sdl` workflow after the config fix and new semantic coverage land.

Appendix

Files And Commits Reviewed

- `proposals/ChainlinkOracleConfigs.sol`
- `proposals/Configs.sol`
- `proposals/mips/mip-x43/mip-x43.sol`
- `src/oracles/ChainlinkOracle.sol`
- `test/integration/LiveProposalsIntegration.t.sol`
- `test/integration/oracle/ChainlinkOEVWrapperIntegration.t.sol`
- `test/unit/ChainlinkOEVWrapperUnit.t.sol`
- `test/invariant/xWELLInvariant.t.sol`
- commit range `85b7a7d70730e8a7aa0255b80acbfd997c211c22..e3579d4832b20162e52f94579b794c30be7dc244`

Runtime And Environment Notes

- Base RPC was loaded from local `.env` through `BASE_RPC_URL`.
- Public endpoints were used for Optimism and Moonbeam during the proposal harness rerun.
- `PRIMARY_FORK_ID=1` was set for the native multichain proposal test path.

Open Questions

- Are there any other changed rows that replace a canonical USD-composed oracle with a raw ratio feed?
- Should semantic oracle-lineage checks live in the repository, the skill, or both?
- Should broad smoke integration be split into a faster semantic gate and a slower liveness sweep?